

Incident Report — SSH Brute-Force Attack (LAB-2026-001)

Executive Summary

On September 5, 2026, the monitored Linux server (deb-target, a hardened Debian 13 host) was targeted by an automated SSH brute-force attack originating from an internal host on the isolated lab network. The attack attempted to gain unauthorized access by rapidly trying many username and password combinations against the server's SSH service.

The attack was both detected and blocked by the security monitoring stack. fail2ban detected the repeated failed login attempts and automatically banned the attacking host mid-attack, and the Wazuh SIEM raised real-time alerts identifying the activity as a brute-force attempt. No unauthorized access was achieved and no data was compromised.

Incident Details

Field	Value
Incident ID	LAB-2026-001
Date of incident	September 5, 2026
Detected by	Wazuh SIEM (rules 5503, 5551) + fail2ban
Attack type	SSH Brute-Force / Password Guessing
MITRE ATT&CK	T1110.001
Affected system	deb-target (Debian 13, hardened)
Affected IP	10.10.10.20
Source of attack	kali (10.10.10.30)
Severity	Medium
Status	Resolved — attack blocked, no compromise

Timeline

All times in local time (CEST, UTC+2). Note: fail2ban logs in local time, while the raw auth.log is in UTC — verified per source.

Time (CEST)	Event
~21:44:21	Attacker (kali, 10.10.10.30) launches an automated SSH brute-force attack against deb-target (10.10.10.20) using Hydra.
21:44:21.9	fail2ban (running locally on the host) detects the rapid failures in auth.log and bans the source IP 10.10.10.30 at the firewall.
21:44:21.9+	Attacker's packets are silently dropped; Hydra keeps retransmitting (visible as TCP retransmissions in the PCAP).
21:44:23	Wazuh processes the forwarded logs (with agent→manager pipeline latency) and fires rule 5503 (level 5) and correlation rule 5551 (level 10), classifying the activity as a brute-force attack.
~21:44:2X	Hydra exhausts its retries and aborts with "0 valid passwords found".

Time (CEST)	Event
	Attack blocked, no access gained.

Note: local, host-based response (fail2ban) reacted ~2 seconds before the centralized SIEM alert, because fail2ban reads auth.log directly while Wazuh's collection pipeline adds latency.

Technical Analysis

Attack Method

The attacker used Hydra to perform an automated SSH brute-force attack (MITRE ATT&CK T1110.001 — Password Guessing) against the target's SSH service on port 22, iterating through candidate usernames and passwords and opening a new SSH connection for each attempt.

Network Evidence (PCAP)

Traffic was captured on the victim host (deb-target, interface ens18) with tcpdump, filtered to SSH traffic (tcp port 22), producing an 821-packet capture. Wireshark analysis revealed:

- **141 connection attempts** from the attacker (filter: tcp.flags.syn == 1 && tcp.flags.ack == 0 && ip.src == 10.10.10.30), far exceeding the 30 real credential combinations — the excess being TCP retransmissions.
- **331 of 821 packets (40%) were TCP retransmissions**, the signature of connections being silently dropped mid-attack by fail2ban's firewall ban.
- **Client banner SSH-2.0-libssh_0.12.0** (vs the server's OpenSSH), indicating scripted, non-human traffic.
- **~0.38 second connection duration** per attempt, machine-speed and far faster than any human login, repeated in a burst.

Log Evidence (auth.log via Wazuh)

Because SSH encrypts credentials in transit, the PCAP proves connections occurred but not their content. The server's auth.log — collected by the Wazuh agent — provides the cleartext detail. Sample raw log:

```
pam_unix(sshd:auth): authentication failure; ... rhost=10.10.10.30  
user=root
```

This reveals the attempted usernames and confirms the source IP, information not available from the encrypted network capture. Network capture (behavior) and host logs (content) are complementary evidence sources.

Detection & Response

Detection (Wazuh SIEM)

The Wazuh agent forwarded SSH authentication logs to the manager, where two rules classified the activity: - **Rule 5503 — “PAM: User login failed” (level 5)**: logged each individual failed login (low-signal noise on its own). - **Rule 5551 — “Multiple failed logins in a small period of time” (level 10)**: a correlation rule that fired on many failures from the same source in a short window, identifying the activity as an attack rather than isolated typos.

Rule 5551 collapses dozens of low-level events into a single actionable, high-severity alert, reducing analyst alert fatigue.

Response (fail2ban)

fail2ban, configured during the server’s Ansible hardening, monitored the same authentication logs and, after a threshold of failed attempts from 10.10.10.30, automatically added a firewall rule banning that IP. The ban silently dropped all further packets, causing Hydra’s connections to time out and retransmit until the tool aborted with “0 valid passwords found”.

Detection and automated response both occurred within seconds of the attack starting, with no human intervention required.

Root Cause

The attack was possible because the SSH service was reachable from the network and accepted password-based authentication, which is inherently exposed to brute-force attempts. In this incident the underlying exposure (password-based SSH) was present, but the hardening applied — specifically fail2ban — acted as a compensating

control that detected and blocked the attack before it could succeed. The attack was contained not by removing the exposure, but by an active defense layered on top of it.

Impact Assessment

Dimension	Impact	Notes
Confidentiality	None	No credentials compromised; no valid access obtained.
Integrity	None	No files, configurations, or data modified.
Availability	Negligible	Server remained operational; only the attacker's own connectivity was affected (by design, via the ban).
Data compromised	None	No data accessed or exfiltrated.
Systems affected	1	deb-target was targeted but not compromised.

Overall impact: None. fail2ban banned the source IP mid-attack, and Hydra terminated without finding valid credentials. The correct password, although present in the attacker's wordlist, was never successfully tested because the attacker was banned before reaching it.

Recommendations

Ordered by priority, from eliminating the root cause to defense-in-depth.

1. **Enforce SSH key-based authentication; disable password login.**
Removes the root cause — brute-force relies on guessing passwords, impossible against key-based auth. Single most effective control.
2. **Disable direct root login (`PermitRootLogin no`).** Logs show attempts against the root account; disabling it removes the highest-value target.
3. **Keep fail2ban active and tune thresholds.** It successfully blocked this attack; review ban duration and retry limits to balance security/usability.
4. **Restrict SSH exposure at the network level.** Limit access to specific source IPs or a management network / VPN.
5. **Consider changing the SSH port (defense-in-depth only).**
Reduces automated scanning noise, but this is obscurity, not real security — it complements, never replaces, the controls above.

Appendices

Appendix A — MITRE ATT&CK Mapping

Tactic	Technique	ID	Detection / Response	Tested
Credential Access	Password Guessing	T1110.001	Wazuh rule 5503 (per-attempt, level 5)	Yes
Credential Access	Password Guessing	T1110.001	Wazuh rule 5551 (correlation, level 10)	Yes
Credential Access	Password Guessing	T1110.001	fail2ban — automated IP ban	Yes

Mapping independently confirmed by Wazuh's built-in MITRE tagging (`rule.mitre.id: T1110.001`, see `../evidence/scans/wazuh-alert-log.json`).

Appendix B — Evidence Files

Paths are relative to this report (located in reports/).

Ref	File	Description
E1	../evidence/ pcaps/ssh-bruteforce.pcap	Full 821-packet capture of the attack.
E2	../evidence/ scans/wazuh-alert-log.json	Raw alert (full_log + MITRE tagging).
E3	../evidence/ screenshots/ wazuh-bruteforce-alerts.png	Dashboard: 38 auth failures, attack spike.
E4	../evidence/ screenshots/ wazuh-bruteforce-ssh-alert.png	Rule 5551 correlation alert in Events.
E5	../evidence/ screenshots/tcp-hydra-bruteforce-pcap.png	141 SYNs — connection attempts.
E6	../evidence/ screenshots/tcp-retransmissions-fail2ban.png	TCP retransmissions caused by the ban.
E7	../evidence/ screenshots/tcp-isolated-connection-ssh-bruteforce.png	Single SSH stream with libssh banner.
E8	../evidence/ scans/lynis-report.dat, ../ evidence/scans/ lynis.log	Lynis hardening scan data (index 68 → 77).

Appendix C — Key Indicators

- Source IP: 10.10.10.30 (kali) · Target IP: 10.10.10.20 (deb-target)
- Attack tool signature: SSH-2.0-libssh_0.12.0
- fail2ban ban: 21:44:21 CEST · Wazuh rules: 5503, 5551
- Targeted account observed in logs: root